

Guía metodológica para la encuesta FAIR-STRIDE

1. Propósito y alcance

Esta guía metodológica acompaña a la encuesta FAIR-STRIDE y establece el modo de diseñar, administrar, interpretar y utilizar los resultados con fines de mejora continua, cumplimiento normativo y toma de decisiones estratégicas de inversión en ciberseguridad. La encuesta está concebida para organizaciones que desean comprender su grado de madurez en la cuantificación económica del riesgo (FAIR) y en el uso estructurado de modelos de amenazas (STRIDE), con especial énfasis en la realidad regulatoria europea y española.

El alcance recomendado abarca a organizaciones de cualquier tamaño y sector, si bien su utilidad es máxima en entidades con cierto grado de formalización en gestión de riesgos, continuidad de negocio y gobierno de TI. Se recomienda aplicarla a nivel de organización, pero puede también desplegarse por unidades de negocio o filiales, siempre que exista una consolidación posterior de resultados.

2. Marcos conceptuales de referencia

La encuesta se apoya en varios marcos consolidados de la práctica y de la regulación:

- La metodología FAIR (Factor Analysis of Information Risk), que propone modelar el riesgo como función de la frecuencia de eventos de pérdida y la magnitud de la pérdida, con resultados expresados en términos económicos.
- El modelo de amenazas STRIDE, ampliamente utilizado en la ingeniería de seguridad, que clasifica amenazas según violan autenticación, integridad, no repudio, confidencialidad, disponibilidad o autorización.
- Las normas ISO 27001 y 27005, así como marcos como NIST CSF y RMF, que establecen requisitos de gestión de riesgos, controles y mejora continua.
- Las directivas y reglamentos europeos relevantes (NIS2, DORA, entre otros), que enfatizan la resiliencia operativa y la capacidad de demostrar un enfoque basado en riesgos.

La encuesta no pretende sustituir a estos marcos, sino servir de puente entre ellos, permitiendo capturar cómo se materializan en la práctica los conceptos de riesgo, amenaza y control, y hasta qué punto la organización ha avanzado en traducirlos a indicadores cuantitativos.

3. Diseño de la encuesta y tipos de preguntas

La encuesta combina preguntas cerradas de opción múltiple con algunas preguntas abiertas, buscando un difícil equilibrio entre la disciplina estadística y el derecho inalienable del CISO a explayarse cuando lo considera oportuno. Las preguntas se agrupan en capítulos que corresponden a dimensiones de madurez FAIR-STRIDE: gobierno del riesgo, modelado de amenazas, propiedades de seguridad, arquitectura, resiliencia, datos y cultura.

Las preguntas cerradas utilizan escalas ordinales que permiten medir el grado de adopción o madurez (por ejemplo, muy alto, alto, medio, bajo, muy bajo) y opciones categóricas sobre marcos normativos, herramientas y prácticas. Se recomienda evitar el síndrome del “todo es medio” recordando a los encuestados que la honestidad es, en estos asuntos, menos cara que un incidente grave.

Las preguntas abiertas, situadas al final del cuestionario, permiten captar matices, obstáculos y aspiraciones que no caben en casillas, y pueden ser analizadas cualitativamente para identificar patrones de barreras organizativas, condicionantes culturales o carencias de talento especializado.

4. Público objetivo dentro de la organización

Idealmente, la encuesta será cumplimentada por la persona con responsabilidad directa sobre la gestión del riesgo de ciberseguridad: CISO, responsable de seguridad de la información, responsable de riesgos tecnológicos o figura equivalente. No obstante, ciertos apartados pueden beneficiarse de la contribución de otras áreas: finanzas, continuidad de negocio, legal, recursos humanos o unidades de negocio con fuerte componente digital.

Es recomendable que, antes de responder, el encuestado consulte con las áreas relevantes para asegurar que las respuestas reflejan la práctica real y no sólo la aspiración recogida en la última presentación al consejo. La guía anima a que, donde existan discrepancias, se documenten y utilicen como punto de partida para diálogos internos.

5. Modo de administración y frecuencia

La encuesta puede administrarse de varias maneras: como cuestionario en línea (preferible para facilitar el tratamiento de datos), en formato documento editable o como entrevista estructurada conducida por un facilitador. La decisión depende del grado de acompañamiento deseado y de la cultura de la organización en materia de autoevaluaciones.

Se recomienda aplicarla, como mínimo, una vez cada 12-18 meses, o bien tras eventos significativos (fusiones, grandes proyectos de transformación, incidentes de alta severidad, cambios regulatorios importantes). El objetivo no es rellenar casillas por deporte, sino observar tendencias y efectos de las decisiones tomadas.

6. Tratamiento y agregación de resultados

Una vez recopiladas las respuestas, se asignará a cada opción de respuesta un valor numérico de madurez (por ejemplo, de 0 a 4). Ello permite calcular índices parciales por dimensión (FAIR, STRIDE, autenticidad, integridad, etc.) e índices globales que reflejen el grado de adopción de FAIR-STRIDE en la organización.

El procesamiento puede hacerse mediante la plantilla de Excel descrita en este kit, que permite obtener indicadores como:

- Índice Global de Madurez (IGM) FAIR-STRIDE.
- Subíndices por dominio (Cuantificación FAIR, Modelado STRIDE, Propiedades de seguridad, Arquitectura Zero Trust, Resiliencia, Datos y cultura).
- Mapas de calor y gráficos temporales para seguimiento de la evolución.

Para evitar el autoengaño estadístico, la guía recomienda revisar los resultados con una mezcla saludable de escepticismo y curiosidad. Si los indicadores son muy altos pero los incidentes siguen abundando, quizá el problema no esté en la hoja de cálculo, sino en la realidad.

7. Interpretación del Índice Global de Madurez (IGM)

El IGM se construye a partir de la media ponderada de los subíndices de las distintas secciones de la encuesta. Se propone, a modo orientativo, una escala de interpretación:

- 0,0 – 1,0: Nivel inicial. La organización se mueve principalmente en modelos cualitativos, sin apenas cuantificación económica ni modelado estructurado de amenazas.
- 1,1 – 2,0: Nivel básico. Existen iniciativas aisladas de cuantificación o modelado, pero no hay enfoque corporativo ni integración con decisiones de negocio.
- 2,1 – 3,0: Nivel intermedio. FAIR y STRIDE se aplican en áreas clave; se utilizan modelos cuantitativos en decisiones relevantes y se observan mejoras en priorización y justificación de inversiones.
- 3,1 – 4,0: Nivel avanzado. La cuantificación FAIR y el modelado STRIDE están integrados en el gobierno de riesgos, la planificación de inversiones y la interacción con reguladores.

Esta escala es indicativa; la verdadera utilidad reside en comparar la organización consigo misma a lo largo del tiempo y, cuando sea posible, con organizaciones de referencia de su sector.

8. Uso de los resultados para decisiones de inversión y ROI

Los resultados de la encuesta deben servir para algo más que engrosar el archivo de PDFs. En particular, pueden emplearse para:

- Identificar dominios donde la cuantificación del riesgo es débil y priorizar proyectos de mejora.
- Vincular la madurez FAIR-STRIDE con decisiones de inversión en controles, resiliencia y talento.
- Preparar argumentarios basados en datos para los órganos de gobierno y reguladores.

La plantilla de Excel de este kit propone un cálculo sencillo de ROI de iniciativas de mejora: se estima la reducción de pérdida anual esperada gracias a un conjunto de controles (utilizando FAIR) y se compara con el coste total de propiedad de dichos controles. A partir de ahí, se obtienen indicadores como periodo de recuperación, ROI en porcentaje y contribución al IGM.

La ironía inevitable es que, a partir de cierto punto, el mayor riesgo no es una vulnerabilidad crítica, sino la tentación de creer que el modelo ha capturado toda la complejidad del mundo. La guía invita a usar los resultados como brújula, no como mapa perfecto.

9. Limitaciones y consideraciones éticas

Ninguna encuesta sustituye a una evaluación profunda de riesgos ni a una auditoría técnica. Las respuestas dependen de la percepción, de la sinceridad y del nivel de información del encuestado. Es crucial que los resultados no se utilicen para “castigar” a áreas o personas, sino para identificar oportunidades de mejora.

Cuando se empleen los resultados con fines comparativos (por ejemplo, entre unidades o filiales), conviene contextualizar las diferencias: recursos disponibles, criticidad de los activos, presión regulatoria y madurez histórica. La desigualdad puede ser, en ocasiones, síntoma de prioridades sensatas.

Desde un punto de vista ético, la encuesta no debería emplearse para justificar recortes indiscriminados bajo la apariencia de eficiencia. Un modelo que “demuestra” que puede recortarse en seguridad sin consecuencias tal vez esté midiendo más la creatividad de quien lo construyó que la realidad del riesgo.

10. Próximos pasos recomendados

Tras la primera aplicación, se sugieren los siguientes pasos:

1. Validar los resultados con las partes interesadas clave y discutir discrepancias.
2. Definir un pequeño número de iniciativas de mejora con alto impacto potencial sobre el IGM.
3. Establecer metas de evolución a 2-3 años y vincularlas a planes de inversión y de talento.
4. Revisar la encuesta periódicamente para mantenerla alineada con cambios tecnológicos y regulatorios.

Si todo va bien, llegará un momento en que la pregunta ya no será “¿tenemos FAIR-STRIDE?”, sino “¿cómo sobrevivíamos antes sin él?”.